

**ĐẠI HỌC QUỐC GIA TP.HCM**

**TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN**



**ĐỒ ÁN MÔN HỌC  
AN TOÀN MẠNG**

**NHẬT KÝ GHI LẠI CÁC CUỘC TẤN CÔNG  
ĐÃ ĐƯỢC PHÁT HIỆN VÀ GIẢM THIỂU**

**BLUE TEAM**

Giảng viên hướng dẫn – TS. Lê Kim Hùng

Sinh viên thực hiện:

23520552 – Phan Cảnh Đăng Huân  
23520479 – Lê Đình Hiếu

## Mục lục

|                                                    |    |
|----------------------------------------------------|----|
| CÁC CUỘC TẤN CÔNG ĐÃ ĐƯỢC GHI NHẬN.....            | 4  |
| 1. Tấn công quét lỗ hổng tự động.....              | 4  |
| Thông tin chung.....                               | 4  |
| Diễn biến tấn công.....                            | 4  |
| Biện pháp phòng thủ & giảm thiểu .....             | 5  |
| Kết luận .....                                     | 6  |
| 2. Tấn công phân tán (DDOS / Botnet) .....         | 6  |
| Thông tin chung.....                               | 6  |
| Diễn biến tấn công.....                            | 7  |
| Biện pháp phòng thủ & giảm thiểu .....             | 9  |
| Kết luận .....                                     | 9  |
| 3. Tấn công dò quét nội bộ (Lateral Movement)..... | 9  |
| Thông tin chung.....                               | 9  |
| Diễn biến chi tiết .....                           | 10 |
| Biện pháp phòng thủ & giảm thiểu .....             | 11 |
| Kết luận .....                                     | 11 |
| 4. Tấn công dò quét dịch vụ cơ sở dữ liệu.....     | 11 |
| Thông tin chung.....                               | 11 |
| Diễn biến chi tiết .....                           | 12 |
| Biện pháp phòng thủ & giảm thiểu .....             | 13 |
| Tổng kết.....                                      | 13 |
| 5. Tấn công dò tìm hệ điều hành.....               | 13 |
| Thông tin chung.....                               | 13 |
| Diễn biến chi tiết .....                           | 13 |
| Biện pháp phòng thủ & giảm thiểu .....             | 15 |
| Kết luận .....                                     | 15 |
| 6. Tấn công Web (SQL Injection) .....              | 15 |
| Thông tin chung.....                               | 16 |
| Diễn biến chi tiết .....                           | 16 |
| Biện pháp phòng thủ & giảm thiểu .....             | 17 |

|                                                       |    |
|-------------------------------------------------------|----|
| Kết luận .....                                        | 17 |
| 7. Tấn công Cross-Site Scripting (XSS) .....          | 18 |
| Thông tin chung.....                                  | 18 |
| Diễn biến chi tiết .....                              | 18 |
| Biện pháp phòng thủ & giảm thiểu .....                | 19 |
| Kết luận .....                                        | 19 |
| 8. Tấn công dò quét lỗ hổng tự động (NSE).....        | 19 |
| Thông tin chung.....                                  | 19 |
| Diễn biến chi tiết .....                              | 20 |
| Biện pháp phòng thủ & giảm thiểu .....                | 21 |
| Kết luận .....                                        | 21 |
| 9. Tấn công thực thi mã từ xa (RCE – SHELLSHOCK)..... | 21 |
| Thông tin chung.....                                  | 21 |
| Diễn biến chi tiết .....                              | 22 |
| Biện pháp phòng thủ & giảm thiểu .....                | 23 |
| Kết luận .....                                        | 23 |

## CÁC CUỘC TẤN CÔNG ĐÃ ĐƯỢC GHI NHẬN

### 1. Tấn công dò quét lỗ hổng tự động

#### Thông tin chung

Ngày phát hiện: 04/12/2025

Đối tượng tấn công (Attacker): IP 172.20.10.7

Mục tiêu: Hệ thống Web Server / DMZ

Phân loại sự cố: Reconnaissance, Brute-force

Công cụ phát hiện : Suricata (IDS/IPS), ModSecurity (WAF), Wazuh (SIEM), pfSense (Firewall)

#### Diễn biến tấn công

Cuộc tấn công diễn ra theo 3 giai đoạn:

#### Giai đoạn 1: Xâm nhập và gửi gói tin (Ghi nhận bởi Suricata)

Thời gian: 14:04:27

Hệ thống phát hiện: Suricata

Last 500 Hosts Blocked by Suricata

Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.

| Blocked IP                                    | Block Date/Time     | Block Alert Description                             | Block Rule GID:SID | Remove Block |
|-----------------------------------------------|---------------------|-----------------------------------------------------|--------------------|--------------|
| 172.20.10.7                                   | 12/04/2025 14:04:27 | SURICATA HTTP Host header invalid                   | 1:2221028          | ✗            |
|                                               | 12/03/2025 13:42:17 | SURICATA Applayer Mismatch protocol both directions | 1:2260000          |              |
| 1 host IP address is currently being blocked. |                     |                                                     |                    |              |

Hành vi kỹ thuật:

- Attacker (172.20.10.7) sử dụng các công cụ quét tự động.
- Công cụ này gửi các HTTP Request có cấu trúc sai quy định (RFC).
- Lỗi cụ thể: **SURICATA HTTP Host header invalid** và **SURICATA Applayer Mismatch protocol both directions**.

Nhận định: Dấu hiệu của việc sử dụng các script fuzzing hoặc scanner để tìm điểm yếu protocol.

#### Giai đoạn 2: Tấn công ứng dụng Web

Thời gian: 14:04:28

## Hệ thống phát hiện: Reverse Proxy & ModSecurity (WAF)

|   |                            |     |                      |       |           |                              |   |       |
|---|----------------------------|-----|----------------------|-------|-----------|------------------------------|---|-------|
| > | Dec 4, 2025 @ 02:04:28.407 | 008 | dmz-reverseproxy-waf |       |           | Web server 400 error code.   | 5 | 31101 |
| > | Dec 4, 2025 @ 02:02:08.575 | 008 | dmz-reverseproxy-waf |       |           | Web server 400 error code.   | 5 | 31101 |
| > | Dec 4, 2025 @ 02:02:08.537 | 008 | dmz-reverseproxy-waf |       |           | Web server 400 error code.   | 5 | 31101 |
| > | Dec 4, 2025 @ 02:02:08.384 | 008 | dmz-reverseproxy-waf |       |           | Web server 400 error code.   | 5 | 31101 |
| > | Dec 4, 2025 @ 02:02:08.247 | 008 | dmz-reverseproxy-waf | T1083 | Discovery | ModSecurity rejected a query | 7 | 31333 |
| > | Dec 4, 2025 @ 02:02:08.244 | 008 | dmz-reverseproxy-waf | T1083 | Discovery | ModSecurity rejected a query | 7 | 31333 |
| > | Dec 4, 2025 @ 02:02:07.041 | 008 | dmz-reverseproxy-waf | T1083 | Discovery | ModSecurity rejected a query | 7 | 31333 |
| > | Dec 4, 2025 @ 02:02:06.555 | 008 | dmz-reverseproxy-waf |       |           | Web server 400 error code.   | 5 | 31101 |

### Hành vi kỹ thuật:

- Reverse Proxy trả về HTTP 400 (Bad Request) do gói tin sai định dạng.
- WAF ghi nhận hành vi dò quét cấu trúc thư mục (Directory traversal/Discovery).
- MITRE ATT&CK: [T1083] **File and Directory Discovery**.

### Giai đoạn 3: Ngăn chặn

| Security Alerts              |       |                  |              |                   |                                                           |       |         |
|------------------------------|-------|------------------|--------------|-------------------|-----------------------------------------------------------|-------|---------|
| Time ↓                       | Agent | Agent name       | Technique(s) | Tactic(s)         | Description                                               | Level | Rule ID |
| > Dec 4, 2025 @ 02:05:23.484 | 000   | h4rrybrwniewazuh | T1110        | Credential Access | Multiple pfSense firewall blocks events from same source. | 10    | 87702   |

Thời gian: 02:05:23

## Hệ thống phát hiện: Wazuh & pfSense

### Hành vi kỹ thuật:

- Attacker chuyển sang spam kết nối hoặc brute-force.
- MITRE ATT&CK: [T1110] **Brute Force**.
- Hành động: pfSense kích hoạt luật chặn IP 172.20.10.7 sau khi vượt ngưỡng cảnh báo.

### Biện pháp phòng thủ & giảm thiểu

| Lớp phòng thủ            | Công cụ     | Hành động cụ thể                            | Hiệu quả                                                                    |
|--------------------------|-------------|---------------------------------------------|-----------------------------------------------------------------------------|
| <b>Network (IPS)</b>     | Suricata    | Phân tích Protocol, phát hiện Header sai.   | Đánh dấu IP đáng ngờ ngay từ gói tin đầu.                                   |
| <b>Application (WAF)</b> | ModSecurity | Kiểm tra HTTP Request, lọc payload độc hại. | Ngăn chặn việc khai thác lỗ hổng Web, giảm tải cho Server (trả về 400/403). |
| <b>Access Control</b>    | pfSense     | Quản lý luật truy cập, Blacklisting.        | Chặn đứng cuộc tấn công, cô lập Attacker khỏi hệ thống.                     |

## Kết luận

Cuộc tấn công quét lỗ hổng từ địa chỉ IP 172.20.10.7 đã được phát hiện và ngăn chặn thành công.

Hiệu quả phòng thủ: Mô hình bảo mật 3 lớp (IPS -> WAF -> Firewall) đã chứng minh hiệu quả cao. Cuộc tấn công bị vô hiệu hóa ngay từ giai đoạn Reconnaissance, ngăn chặn Attacker tiến tới các giai đoạn nguy hiểm hơn như Exploitation hay Installation.

Thiệt hại: Không có. Tính toàn vẹn và sẵn sàng của hệ thống DMZ được đảm bảo. Không có dữ liệu nào bị rò rỉ.

Bài học kinh nghiệm: Việc giám sát log tập trung (SIEM) là cực kỳ quan trọng để xâu chuỗi các sự kiện rời rạc thành một bức tranh toàn cảnh, giúp Blue Team phản ứng nhanh và chính xác.

## 2. Tấn công phân tán (DDOS / Botnet)

### Thông tin chung

Thời gian: Từ 14:04:27 đến 14:45:38 ngày 04/12/2025

Đối tượng tấn công:

- Attacker 1 (WAN): IP 172.20.10.7
- Attacker 2: Botnet gồm nhiều IP rải rác

Loại hình tấn công:

- Reconnaissance & Fuzzing
- Distributed TCP Anomaly/Flood

Công cụ phát hiện: Suricata (IDS/IPS), Wazuh (SIEM)

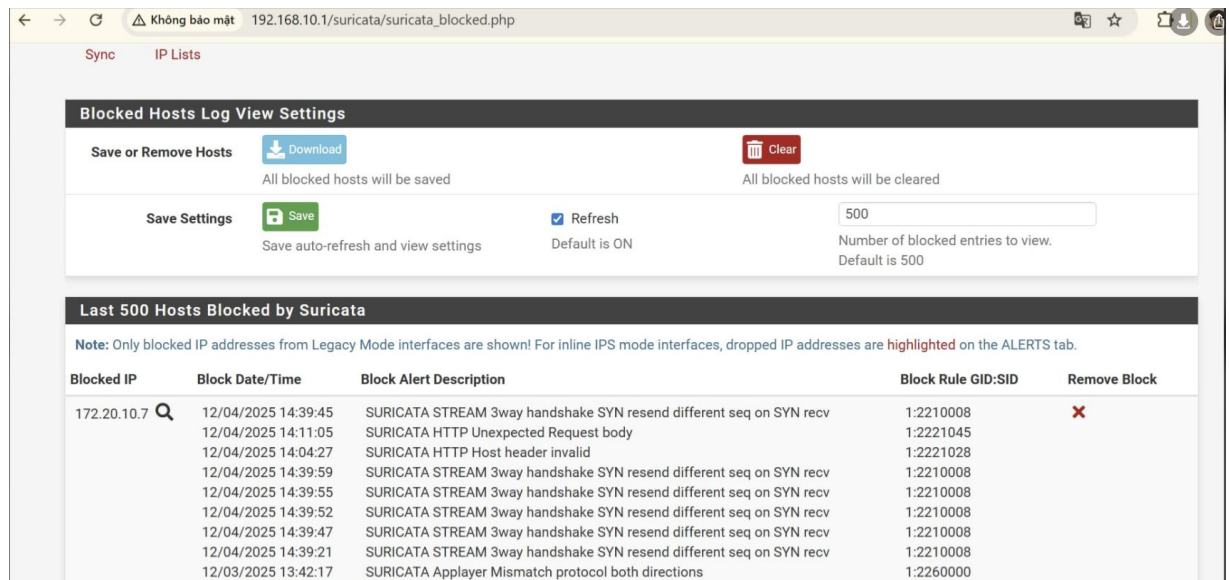
## Diễn biến tấn công

Cuộc tấn công diễn ra theo hai hướng, nhằm vào sự ổn định của giao thức mạng:

### Giai đoạn 1: Recon

Thời gian: 14:04:27 – 14:39:59.

Nguồn: IP 172.20.10.7.



| Blocked IP  | Block Date/Time     | Block Alert Description                                            | Block Rule ID:SID | Remove Block |
|-------------|---------------------|--------------------------------------------------------------------|-------------------|--------------|
| 172.20.10.7 | 12/04/2025 14:39:45 | SURICATA STREAM 3way handshake SYN resend different seq on SYN rcv | 1:2210008         | ✗            |
|             | 12/04/2025 14:11:05 | SURICATA HTTP Unexpected Request body                              | 1:2221045         |              |
|             | 12/04/2025 14:04:27 | SURICATA HTTP Host header invalid                                  | 1:2221028         |              |
|             | 12/04/2025 14:39:59 | SURICATA STREAM 3way handshake SYN resend different seq on SYN rcv | 1:2210008         |              |
|             | 12/04/2025 14:39:55 | SURICATA STREAM 3way handshake SYN resend different seq on SYN rcv | 1:2210008         |              |
|             | 12/04/2025 14:39:52 | SURICATA STREAM 3way handshake SYN resend different seq on SYN rcv | 1:2210008         |              |
|             | 12/04/2025 14:39:47 | SURICATA STREAM 3way handshake SYN resend different seq on SYN rcv | 1:2210008         |              |
|             | 12/04/2025 14:39:21 | SURICATA STREAM 3way handshake SYN resend different seq on SYN rcv | 1:2210008         |              |
|             | 12/03/2025 13:42:17 | SURICATA Applayer Mismatch protocol both directions                | 1:2260000         |              |

Hành vi kỹ thuật:

- Attacker gửi các gói tin HTTP Request với Header không hợp lệ (**SURICATA HTTP Host Header invalid**) nhằm kiểm tra phản ứng của Web Server.
- Sau đó thực hiện hành vi spam kết nối TCP khiến quá trình bắt tay 3 bước bị lỗi lặp lại (**3way handshake SYN resend different seq**).

Nhận định: Đây có thể là Attacker đang cố gắng Recon hệ thống.

### Giai đoạn 2: Tấn công phân tán

Thời gian: 14:45:36 – 14:45:38

Nguồn: Hàng loạt địa chỉ IP Public khác nhau (194.x.x.x, 159.x.x.x, 42.x.x.x, ...) tấn công đồng loạt.

|                 |                                                                                                                                                                     |                     |                                                    |           |   |
|-----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|----------------------------------------------------|-----------|---|
| 194.239.118.243 |   | 12/04/2025 14:45:36 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 198.90.180.54   |   | 12/04/2025 14:45:36 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 218.222.31.169  |   | 12/04/2025 14:45:36 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 65.114.49.224   |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 159.9.172.72    |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 145.150.85.107  |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 190.128.94.239  |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 42.239.19.222   |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 205.184.109.240 |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 142.72.231.229  |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 107.160.184.32  |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 32.224.44.149   |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 159.156.7.136   |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 163.94.218.11   |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 183.110.130.159 |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 72.155.230.89   |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 40.160.159.202  |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 203.22.6.130    |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |
| 160.211.10.127  |   | 12/04/2025 14:45:38 | SURICATA STREAM 3way handshake wrong seq wrong ack | 1:2210010 | ✗ |

Hành vi kỹ thuật:

- Hệ thống ghi nhận hàng loạt cảnh báo **SURICATA STREAM 3way handshake wrong seq wrong ack**.
- Các gói tin này chứa Sequence Number và Acknowledgement Number sai so với trạng thái kết nối TCP chuẩn.

Nhận định: Dấu hiệu điển hình của một cuộc tấn công từ chối dịch vụ phân tán (DDOS) hoặc Botnet sử dụng kỹ thuật TCP Spoofing. Attacker có thể làm giả gói tin hoặc gửi gói tin bất hợp lệ để làm tràn State Table của Firewall/IPS.

### Giai đoạn 3: Cảnh báo & xử lý

Thời gian: Hệ thống Wazuh (SIEM) ghi nhận các đợt chặn từ Firewall vào lúc 14:44:23.

| Security Alerts              |       |                  |              |                   |                                                           |       |         |
|------------------------------|-------|------------------|--------------|-------------------|-----------------------------------------------------------|-------|---------|
| Time ↓                       | Agent | Agent name       | Technique(s) | Tactic(s)         | Description                                               | Level | Rule ID |
| > Dec 4, 2025 @ 02:44:23.646 | 000   | h4rrybrwniewazuh | T1110        | Credential Access | Multiple pfSense firewall blocks events from same source. | 10    | 87702   |
| > Dec 4, 2025 @ 02:39:22.091 | 000   | h4rrybrwniewazuh | T1110        | Credential Access | Multiple pfSense firewall blocks events from same source. | 10    | 87702   |

Hành động: Wazuh kích hoạt **Rule ID 87702** với mô tả “**Multiple pfSense firewall blocks events from same source**”.

Kết quả: Suricata tự động chặn các gói tin vi phạm, bảo vệ Web Server không phải xử lý các kết nối rác này.

## Biện pháp phòng thủ & giảm thiểu

| Lớp phòng thủ             | Vai trò                                                                                                                                                                         |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>IPS (Suricata)</b>     | Protocol Validation: Phát hiện các vi phạm quy tắc TCP/IP (Wrong Seq/Ack) và HTTP RFC (Invalid Header). Suricata đóng vai trò chốt chặn đầu tiên, loại bỏ các gói tin đáng ngờ. |
| <b>SIEM (Wazuh)</b>       | Correlation: Tổng hợp các sự kiện chặn rời rạc từ Firewall thành một cảnh báo bảo mật cấp độ 10 (Level 10), giúp quản trị viên nhận diện được quy mô cuộc tấn công.             |
| <b>Firewall (pfSense)</b> | Blocking: Thực thi lệnh chặn IP dựa trên tín hiệu từ Suricata.                                                                                                                  |

## Kết luận

Cuộc tấn công Recon (từ địa chỉ IP 172.20.10.7 và mạng botnet) nhắm vào lớp giao thức mạng đã được phát hiện và ngăn chặn hoàn toàn.

Hiệu quả phòng thủ: Cơ chế phòng thủ chiều sâu (Defense-in-Depth) kết hợp giữa phát hiện bất thường giao thức của Suricata và các luật chặn của Firewall đã phát huy tác dụng. Hệ thống đã nhận diện chính xác các gói tin vi phạm chuẩn RFC (Wrong Seq/Ack, Invalid Header), vô hiệu hóa tấn công ngay giai đoạn Reconnaissance, ngăn chặn Attacker thực hiện thành công quy trình bắt tay 3 bước để xâm nhập sâu hơn.

Thiệt hại: Không có. Tính sẵn sàng của dịch vụ Web và hạ tầng mạng được đảm bảo tuyệt đối trước nỗ lực làm tràn (Flood) giao thức. Không có dữ liệu bị rò rỉ hay mã độc nào được cài đặt vào hệ thống DMZ.

Bài học kinh nghiệm: Sự cố này làm nổi bật tầm quan trọng của việc phân vùng mạng. Việc xác định rõ ranh giới giữa vùng Untrusted (WAN) và Trusted (LAN/DMZ) giúp các luật của IPS/IDS hoạt động chính xác.

## 3. Tấn công dò quét nội bộ

### Thông tin chung

Thời gian: 21:44:08 – 21:44:10 ngày 08/12/2025

Đối tượng tấn công:

- IP nguồn: 192.168.40.10 (LAN30 – Employee Computer)
- Nghi vấn: Thiết bị có dấu hiệu bị nhiễm mã độc hoặc bị điều khiển từ xa

Mục tiêu:

- Toàn bộ dải mạng LAN40 (192.168.50.0/24)

Loại hình tấn công: Internal Reconnaissance / Port Scanning

Công cụ phát hiện và ngăn chặn : pfSense Firewall

| Last 500 Firewall Log Entries. (Maximum 500) |                |           |                                     |                     |                    |          |
|----------------------------------------------|----------------|-----------|-------------------------------------|---------------------|--------------------|----------|
| Action                                       | Time           | Interface | Rule                                | Source              | Destination        | Protocol |
| ✗                                            | Dec 8 21:44:08 | LAN30     | (@131)                              | 192.168.40.10:33006 | 192.168.50.3:1025  | TCP:S    |
| ✗                                            | Dec 8 21:44:08 | LAN30     | (@131)                              | 192.168.40.10:33006 | 192.168.50.4:23    | TCP:S    |
| ✗                                            | Dec 8 21:44:08 | LAN30     | (@131)                              | 192.168.40.10:33006 | 192.168.50.7:110   | TCP:S    |
| ✗                                            | Dec 8 21:44:08 | LAN40     | (@139)                              | 192.168.50.10:57352 | 8.8.8.8:53         | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN30     | (@131)                              | 192.168.40.10:33007 | 192.168.50.2:587   | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN30     | (@131)                              | 192.168.40.10:33007 | 192.168.50.0:21    | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN30     | (@131)                              | 192.168.40.10:33007 | 192.168.50.3:1025  | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN30     | (@131)                              | 192.168.40.10:33007 | 192.168.50.4:23    | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN30     | (@131)                              | 192.168.40.10:33007 | 192.168.50.1:8080  | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN30     | (@131)                              | 192.168.40.10:33007 | 192.168.50.60:110  | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN30     | (@131)                              | 192.168.40.10:33007 | 192.168.50.62:8080 | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN30     | (@131)                              | 192.168.40.10:33007 | 192.168.50.61:135  | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN30     | (@131)                              | 192.168.40.10:33007 | 192.168.50.63:256  | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN30     | (@131)                              | 192.168.40.10:33007 | 192.168.50.7:110   | TCP:S    |
| ✗                                            | Dec 8 21:44:09 | LAN40     | (@139)                              | 192.168.50.20:58196 | 8.8.8.8:53         | TCP:S    |
| ✗                                            | Dec 8 21:44:10 | LAN20     | Default deny rule IPv4 (1000000103) | 192.168.30.10:47662 | 8.8.8.8:53         | TCP:S    |
| ✗                                            | Dec 8 21:44:10 | LAN30     | (@131)                              | 192.168.40.10:33006 | 192.168.50.15:139  | TCP:S    |
| ✗                                            | Dec 8 21:44:10 | LAN30     | (@131)                              | 192.168.40.10:33006 | 192.168.50.16:21   | TCP:S    |
| ✗                                            | Dec 8 21:44:10 | LAN30     | (@131)                              | 192.168.40.10:33006 | 192.168.50.17:1025 | TCP:S    |

## Diễn biến chi tiết

Cuộc tấn công diễn ra theo kịch bản quét port từ bên trong mạng nội bộ

### Giai đoạn 1 : Bắt đầu tấn công

Bối cảnh : Máy 192.168.40.10 tại LAN30 bất ngờ thực hiện hàng loạt kết nối ra ngoài vùng mạng của nó.

Hành vi kỹ thuật :

- Thiết bị gửi hàng loạt gói tin TCP SYN đến các địa chỉ ngẫu nhiên trong dải mạng LAN40 (192.168.50.x)
- Công dịch vụ bị nhắm đến : Attacker không tập trung vào một dịch vụ mà quét nhiều cổng phổ biến : 23 (Telnet), 21 (FTP), 110 (POP3), 587 (SMTP), 139 (NetBIOS), 8080 (Web Proxy), ...

Nhận định : Đây là các dấu hiệu của hành vi đang dùng tool quét mạng (như Nmap) để tìm máy nạn nhân tiếp theo trong mạng nội bộ.

### Giai đoạn 2 : Ngăn chặn

Thời gian : Ngay lập tức tại thời điểm 21 :44 :08.

Cơ chế phòng thủ :

- Firewall pfSense ghi nhận lưu lượng đi từ LAN30 sang LAN40 vi phạm chính sách bảo mật
- Luật chặn được kích hoạt
- Các luật cụ thể: **(@131)**, **(@139)** và **Default deny rule IPv4**

Kết quả: Các nỗ lực kết nối từ 192.168.40.10 sang dải mạng 192.168.50.x bị từ chối

### **Biện pháp phòng thủ & giảm thiểu**

Trong sự cố này, việc phân vùng mạng đã ngăn chặn thành công các nỗ lực Lateral Movement để kết nối đến các mạng nội bộ khác.

| <b>Lớp phòng thủ</b>        | <b>Vai trò &amp; Hiệu quả</b>                                                                                                                                             |
|-----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Network Segmentation</b> | Việc tách máy nhân viên (LAN30) và các vùng mạng khác (LAN40) thành các mạng riêng biệt là chốt chặn quan trọng nhất. Nếu chung mạng có thể mã độc đã lây lan thành công. |
| <b>Firewall Rules (ACL)</b> | Chính sách Zero Trust giữa các vùng nội bộ đã phát huy tác dụng. Firewall không ngầm định tin tưởng lưu lượng chỉ vì nó xuất phát từ mạng nội bộ.                         |

### **Kết luận**

Cuộc tấn công là một nỗ lực Lateral Movement thất bại. Attacker (hoặc mã độc) đã cố gắng tìm kiếm các thiết bị có lỗ hổng (mở port Telnet, NetBIOS, ...) ở mạng lân cận để lây nhiễm tiếp nhưng bị chặn bởi Firewall.

Đánh giá: Mặc dù tấn công sang LAN40 thất bại, nhưng việc máy 192.168.40.10 thực hiện hành vi này chứng tỏ LAN30 đã bị xâm nhập. Mối nguy hiểm hiện tại nằm tại ngay tại máy tính của nhân viên này.

## **4. Tấn công dò quét dịch vụ cơ sở dữ liệu**

### **Thông tin chung**

Thời gian: 14:59:12 ngày 09/12/2025

Đối tượng tấn công:

- IP nguồn: 172.20.10.3
- Vị trí: Vùng WAN

Mục tiêu:

- IP đích: 172.20.10.2
- Nhắm đến các hệ quản trị cơ sở dữ liệu (DBMS)

Phân loại sự cố: Service Scanning / Pre-Exploitation

## Diễn biến chi tiết

Cuộc tấn công mang tính chất rõ rệt nhắm vào nơi lưu trữ dữ liệu (Database).

### Giai đoạn 1: Dò quét

Thời gian: 14:59:12

|                     |  |   |     |                         |                 |       |                 |      |               |                                                    |
|---------------------|--|---|-----|-------------------------|-----------------|-------|-----------------|------|---------------|----------------------------------------------------|
| 12/09/2025 14:59:13 |  | 2 | TCP | Potentially Bad Traffic | 172.20.10.3<br> | 46683 | 172.20.10.2<br> | 5432 | 1:2010939<br> | ET SCAN Suspicious inbound to PostgreSQL port 5432 |
| 12/09/2025 14:59:13 |  | 2 | TCP | Potentially Bad Traffic | 172.20.10.3<br> | 46685 | 172.20.10.2<br> | 1433 | 1:2010935<br> | ET SCAN Suspicious inbound to MSSQL port 1433      |
| 12/09/2025 14:59:13 |  | 2 | TCP | Potentially Bad Traffic | 172.20.10.3<br> | 46685 | 172.20.10.2<br> | 5432 | 1:2010939<br> | ET SCAN Suspicious inbound to PostgreSQL port 5432 |
| 12/09/2025 14:59:12 |  | 2 | TCP | Potentially Bad Traffic | 172.20.10.3<br> | 46685 | 172.20.10.2<br> | 3306 | 1:2010937<br> | ET SCAN Suspicious inbound to MySQL port 3306      |
| 12/09/2025 14:59:12 |  | 2 | TCP | Potentially Bad Traffic | 172.20.10.3<br> | 46683 | 172.20.10.2<br> | 1433 | 1:2010935<br> | ET SCAN Suspicious inbound to MSSQL port 1433      |
| 12/09/2025 14:59:12 |  | 2 | TCP | Potentially Bad Traffic | 172.20.10.3<br> | 46683 | 172.20.10.2<br> | 3306 | 1:2010937<br> | ET SCAN Suspicious inbound to MySQL port 3306      |

Hành vi kỹ thuật:

- Attacker (172.20.10.3) sử dụng các công cụ quét tự động gửi các gói tin TCP SYN đến hàng loạt các cổng mặc định của các Database phổ biến: 3306 (MySQL / MariaDB), 1433 (Microsoft SQL Server (MSSQL), 5432 (PostgreSQL).

Nhận định: Hệ thống kích hoạt luật **ET SCAN Suspicious inbound to [db\_name] port**. Điều này cho thấy gói tin khớp với chữ ký các tool scan database chuyên dụng.

### Giai đoạn 2: Ngăn chặn

Thời gian: 14:59:12, Suricata đã đưa IP 172.20.10.3 vào Block List.

| Last 500 Hosts Blocked by Suricata                                                                                                                                           |                     |                                               |                    |              |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|-----------------------------------------------|--------------------|--------------|
| <b>Note:</b> Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are <b>highlighted</b> on the ALERTS tab. |                     |                                               |                    |              |
| Blocked IP                                                                                                                                                                   | Block Date/Time     | Block Alert Description                       | Block Rule GID:SID | Remove Block |
| 172.20.10.3                                                                                                                                                                  | 12/09/2025 14:59:12 | ET SCAN Suspicious inbound to MySQL port 3306 | 1:2010937          |              |

### Giai đoạn 3: Cảnh báo

Thời gian: 14:58:36

Hành vi:

- Sau khi bị Suricata chặn, Attacker vẫn tiếp tục gửi các gói tin khác, dẫn đến Firewall drop gói tin liên tục.
- Wazuh kích hoạt **Rule ID 87702 (Level 10) – Multiple pfSense firewall blocks events from same source**, đánh dấu kỹ thuật tấn công **T1110 – Credential Access**.

| Security Alerts              |       |                  |              |                   |                                                           |       |         |
|------------------------------|-------|------------------|--------------|-------------------|-----------------------------------------------------------|-------|---------|
| Time ↓                       | Agent | Agent name       | Technique(s) | Tactic(s)         | Description                                               | Level | Rule ID |
| > Dec 9, 2025 @ 02:58:36.057 | 000   | h4rrybrwniewazuh | T1110        | Credential Access | Multiple pfSense firewall blocks events from same source. | 10    | 87702   |

## Biện pháp phòng thủ & giảm thiểu

| Lớp phòng thủ      | Vai trò                                                                                                                                      |
|--------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| IPS (Suricata)     | Phát hiện hành vi: Suricata không chỉ nhìn thấy kết nối TCP, mà còn nhận diện được nỗ lực nhắm vào các dịch vụ SQL cụ thể (MySQL, MSSQL...). |
| Firewall (pfSense) | Chặn đứng kết nối ngay tại WAN, đảm bảo Attacker không thể chạm được tới Database Server thật sự nằm trong vùng DMZ/LAN.                     |
| SIEM (Wazuh)       | Cảnh báo mức độ cao: Nâng mức độ cảnh báo lên Level 10 vì tấn công vào Database luôn được coi là nghiêm trọng hơn tấn công Web thông thường. |

## Tổng kết

Cuộc tấn công dò quét cơ sở dữ liệu từ địa chỉ IP 172.20.10.3 đã bị vô hiệu hóa. Attacker đang cố gắng tìm kiếm các server cơ sở dữ liệu bị cấu hình sai (mở port ra Internet) để thực hiện tấn công Brute-force mật khẩu hoặc khai thác SQL Injection.

Thiệt hại: Không có. Không có kết nối nào được thiết lập, dữ liệu an toàn.

Bài học kinh nghiệm: Sự cố này khẳng định tầm quan trọng của việc không public cơ sở dữ liệu ra Internet. Việc Attacker quét được cổng 3306/1433 từ WAN cho thấy chúng đang Blind Scanning. Nếu Firewall không chặn, rủi ro lộ dữ liệu là rất lớn.

## 5. Tấn công dò quét hệ điều hành

### Thông tin chung

Thời gian: 15:30:26 ngày 09/12/2025.

Đối tượng tấn công: IP nguồn 172.20.10.3

Mục tiêu: 172.20.10.2

Công cụ tấn công: Nmap

Loại hình tấn công: Active Fingerprinting / OS Detection

### Diễn biến chi tiết

Cuộc tấn công sử dụng các kỹ thuật đặc thù nhằm xác định hệ điều hành của máy chủ.

### Giai đoạn 1: Gửi gói tin thăm dò

Thời gian: 15:30:26

| Date                | Action                                                                              | Pri | Proto | Class                           | Src                  | SPort | Dst                | DPort | GID:SID          | Description                     |
|---------------------|-------------------------------------------------------------------------------------|-----|-------|---------------------------------|----------------------|-------|--------------------|-------|------------------|---------------------------------|
| 12/09/2025 15:30:30 |    | 2   | UDP   | Attempted Information Leak      | 172.20.10.3<br>Q ⊕ X | 40978 | 172.20.10.2<br>Q ⊕ | 40214 | 1:2018489<br>⊕ X | ET SCAN NMAP OS Detection Probe |
| 12/09/2025 15:30:30 |    | 3   | ICMP  | Generic Protocol Command Decode | 172.20.10.3<br>Q ⊕ X | 8     | 172.20.10.2<br>Q ⊕ | 9     | 1:2200025<br>⊕ X | SURICATA ICMPv4 unknown code    |
| 12/09/2025 15:30:29 |    | 2   | UDP   | Attempted Information Leak      | 172.20.10.3<br>Q ⊕ X | 40978 | 172.20.10.2<br>Q ⊕ | 40214 | 1:2018489<br>⊕ X | ET SCAN NMAP OS Detection Probe |
| 12/09/2025 15:30:29 |    | 3   | ICMP  | Generic Protocol Command Decode | 172.20.10.3<br>Q ⊕ X | 8     | 172.20.10.2<br>Q ⊕ | 9     | 1:2200025<br>⊕ X | SURICATA ICMPv4 unknown code    |
| 12/09/2025 15:30:29 |    | 3   | ICMP  | Generic Protocol Command Decode | 172.20.10.3<br>Q ⊕ X | 8     | 172.20.10.2<br>Q ⊕ | 9     | 1:2200025<br>⊕ X | SURICATA ICMPv4 unknown code    |
| 12/09/2025 15:30:29 |    | 2   | UDP   | Attempted Information Leak      | 172.20.10.3<br>Q ⊕ X | 40978 | 172.20.10.2<br>Q ⊕ | 40214 | 1:2018489<br>⊕ X | ET SCAN NMAP OS Detection Probe |
| 12/09/2025 15:30:28 |    | 3   | ICMP  | Generic Protocol Command Decode | 172.20.10.3<br>Q ⊕ X | 8     | 172.20.10.2<br>Q ⊕ | 9     | 1:2200025<br>⊕ X | SURICATA ICMPv4 unknown code    |
| 12/09/2025 15:30:28 |    | 2   | UDP   | Attempted Information Leak      | 172.20.10.3<br>Q ⊕ X | 40978 | 172.20.10.2<br>Q ⊕ | 40214 | 1:2018489<br>⊕ X | ET SCAN NMAP OS Detection Probe |
| 12/09/2025 15:30:26 |    | 2   | UDP   | Attempted Information Leak      | 172.20.10.3<br>Q ⊕ X | 40722 | 172.20.10.2<br>Q ⊕ | 40152 | 1:2018489<br>⊕ X | ET SCAN NMAP OS Detection Probe |
| 12/09/2025 15:30:26 |    | 2   | UDP   | Attempted Information Leak      | 172.20.10.3<br>Q ⊕ X | 40722 | 172.20.10.2<br>Q ⊕ | 40152 | 1:2018489<br>⊕ X | ET SCAN NMAP OS Detection Probe |
| 12/09/2025 15:30:26 |    | 3   | ICMP  | Generic Protocol Command Decode | 172.20.10.3<br>Q ⊕ X | 8     | 172.20.10.2<br>Q ⊕ | 9     | 1:2200025<br>⊕ X | SURICATA ICMPv4 unknown code    |
| 12/09/2025 15:30:26 |  | 3   | ICMP  | Generic Protocol Command Decode | 172.20.10.3<br>Q ⊕ X | 8     | 172.20.10.2<br>Q ⊕ | 9     | 1:2200025<br>⊕ X | SURICATA ICMPv4 unknown code    |
| 12/09/2025 15:30:26 |  | 3   | ICMP  | Generic Protocol Command Decode | 172.20.10.3<br>Q ⊕ X | 8     | 172.20.10.2<br>Q ⊕ | 9     | 1:2200025<br>⊕ X | SURICATA ICMPv4 unknown code    |
| 12/09/2025 15:30:26 |  | 3   | ICMP  | Generic Protocol Command Decode | 172.20.10.3<br>Q ⊕ X | 8     | 172.20.10.2<br>Q ⊕ | 9     | 1:2200025<br>⊕ X | SURICATA ICMPv4 unknown code    |
| 12/09/2025 15:30:26 |  | 2   | UDP   | Attempted Information Leak      | 172.20.10.3<br>Q ⊕ X | 40722 | 172.20.10.2<br>Q ⊕ | 40152 | 1:2018489<br>⊕ X | ET SCAN NMAP OS Detection Probe |

Hành vi kỹ thuật:

- Attacker gửi liên tục các gói tin **ICMP (SURICATA ICMPv4 unknown code)**.

Mục đích: Mỗi hệ điều hành (Windows, Linux, FreeBSD, ...) có cách phản hồi khác nhau đối với các gói tin ICMP không đúng chuẩn. Attacker lợi dụng điều này để đoán xem server đang chạy Win hay Linux.

## Giai đoạn 2: Công cụ Nmap

Thời gian: 15:30:29

Cảnh báo: Hệ thống phát hiện chữ ký tấn công: **ET SCAN NMAP OS Detection Probe**.

Giao thức: Sử dụng cả UDP và ICMP. Log ghi nhận **Attempted Information Leak** qua giao thức UDP ở các port (40214 -> 40978). Đây là các hành vi đặc trưng của lệnh nmap -O (OS Detection).

### Giai đoạn 3: Ngăn chặn

Suricata chặn IP 172.20.10.3 dựa trên **Rule ID 1:2018489** (Nmap OS Detection) và **1:2200025 (ICMP Unknown Code)**.

| Blocked IP                                                                                    | Block Date/Time     | Block Alert Description         | Block Rule GID:SID | Remove Block                                                                        |
|-----------------------------------------------------------------------------------------------|---------------------|---------------------------------|--------------------|-------------------------------------------------------------------------------------|
| 172.20.10.3  | 12/09/2025 15:30:29 | SURICATA ICMPv4 unknown code    | 1:2200025          |  |
|                                                                                               | 12/09/2025 15:30:26 | ET SCAN NMAP OS Detection Probe | 1:2018489          |                                                                                     |
|                                                                                               | 12/09/2025 15:30:26 | SURICATA ICMPv4 unknown code    | 1:2200025          |                                                                                     |

### Biện pháp phòng thủ & giảm thiểu

Trong cuộc tấn công này, hệ thống phòng thủ đã áp dụng chiến lược che giấu thông tin kết hợp với chặn chủ động để ngăn chặn Attacker.

| Lớp phòng thủ      | Cơ chế hoạt động & Hiệu quả                                                                                                                                                                                                                                                                                                                                                                              |
|--------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| IPS (Suricata)     | Suricata đã so khớp chính xác các gói tin của Nmap với bộ luật <b>Emerging Threats (ET)</b> .<br>- <b>Rule 1:2018489</b> (Nmap OS Detection Probe) phát hiện các gói UDP có cấu trúc lạ.<br>- <b>Rule 1:2200025 (ICMP unknown code)</b> phát hiện hành vi thăm dò phản hồi ICMP sai chuẩn.<br>Kết quả: Ngắt kết nối ngay lập tức, khiến Nmap không nhận đủ dữ liệu phản hồi để so sánh với cơ sở dữ liệu |
| Firewall (pfSense) | Firewall được cấu hình để DROP gói tin thay vì REJECT.<br>- Nếu REJECT: Attacker nhận được gói tin báo lỗi -> Vẫn thu thập được thông tin.<br>- Nếu DROP: Hacker không nhận được gì cả -> Nmap sẽ bị treo hoặc báo kết quả không chính xác/không xác định được OS.                                                                                                                                       |

### Kết luận

Attacker (172.20.10.3) sau khi thất bại trong việc quét Database đã chuyển sang bước kế tiếp để tìm kiếm cách khai thác lỗ hổng đặc thù của hệ điều hành. Tuy nhiên, hành vi sử dụng Nmap đã bị IPS phát hiện.

Hiệu quả phòng thủ: Việc chặn đứng OS Fingerprinting là rất quan trọng. Nếu Attacker không biết Server chạy OS gì, chúng sẽ rất khó chọn đúng cách khai thác, làm giảm tỉ lệ thành công.

### 6. Tấn công Web (SQL Injection)

## Thông tin chung

Thời gian: 16:34:50 ngày 09/12/2025.

Đối tượng tấn công:

- IP nguồn: 172.20.10.3

Mục tiêu:

- Hệ thống dmz-reverseproxy-waf (Máy chủ Reverse Proxy có cài WAF)
- IP đích: 172.20.10.2

Loại hình tấn công:

- SQL Injection (SQLi)
- Directory Traversal / Forced Browsing

## Diễn biến chi tiết

Cuộc tấn công nhằm thẳng vào ứng dụng Web thông qua cổng 80, cố gắng khai thác lỗ hổng đầu vào dữ liệu.

### Giai đoạn 1: SQLi

Thời gian: 16:34:50.

| Security Alerts              |       |                      |              |                |                              |       |         |
|------------------------------|-------|----------------------|--------------|----------------|------------------------------|-------|---------|
| Time ↓                       | Agent | Agent name           | Technique(s) | Tactic(s)      | Description                  | Level | Rule ID |
| > Dec 9, 2025 @ 04:34:50.935 | 008   | dmz-reverseproxy-waf | T1083        | Discovery      | ModSecurity rejected a query | 7     | 31333   |
| > Dec 9, 2025 @ 04:34:50.933 | 008   | dmz-reverseproxy-waf | T1190        | Initial Access | SQL injection attempt.       | 7     | 31103   |

Hành vi kỹ thuật:

- Attacker gửi một HTTP Request có chứa payload độc hại nhằm vào cơ sở dữ liệu.
- Wazuh Alert: Kích hoạt **Rule ID 31103 – SQL Injection attempt.**
- Kỹ thuật MITRE ATT&CK: **T1109 (Exploit Public – Facing Application).**

Phản ứng của WAF : ModSecurity trên máy dmz-reverseproxy-waf đã phát hiện chuỗi ký tự SQL bất thường và ngay lập tức từ chối xử lý request này.

- Wazuh Alert : **Rule ID 31333 – ModSecurity rejected a query.**

### Giai đoạn 2: Phản hồi

Thời gian 16:34:58

| Alert Log View Filter                                          |        |     |       |                            |             |       |             |       |           |                              |
|----------------------------------------------------------------|--------|-----|-------|----------------------------|-------------|-------|-------------|-------|-----------|------------------------------|
| Last 250 Alert Entries. (Most recent entries are listed first) |        |     |       |                            |             |       |             |       |           |                              |
| Date                                                           | Action | Pri | Proto | Class                      | Src         | SPort | Dst         | DPort | GID:SID   | Description                  |
| 12/09/2025 16:34:58                                            |        | 2   | TCP   | Attempted Information Leak | 172.20.10.2 | 80    | 172.20.10.3 | 58516 | 1:2101201 | GPL WEB_SERVER 403 Forbidden |

Hành vi kỹ thuật:

- Do bị WAF chặn hoặc do truy cập vào đường dẫn không cho phép, Web Server trả về HTTP 403 Forbidden.
- Cảnh báo Suricata: **GPL WEB\_SERVER 403 Forbidden (GID:SID 1:2101201)**.

Phân loại: Suricata xếp lại hành vi này là **Attempted Information Leak**.

### Giai đoạn 3 : Ngăn chặn

Suricata tiếp tục duy trì lệnh chặn đối với IP 172.20.10.3.

| Last 500 Hosts Blocked by Suricata                                                                                                                             |                                            |                                                                                     |                        |              |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------|-------------------------------------------------------------------------------------|------------------------|--------------|
| Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab. |                                            |                                                                                     |                        |              |
| Blocked IP                                                                                                                                                     | Block Date/Time                            | Block Alert Description                                                             | Block Rule GID:SID     | Remove Block |
| 172.20.10.3                                                                                                                                                    | 12/09/2025 16:14:27<br>12/09/2025 16:34:58 | SURICATA Applayer Mismatch protocol both directions<br>GPL WEB_SERVER 403 Forbidden | 1:2260000<br>1:2101201 |              |

### Biện pháp phòng thủ & giảm thiểu

| Lớp phòng thủ     | Vai trò                                                                                                                                                                                                 |
|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| WAF (ModSecurity) | WAF đã phân tích payload của gói tin HTTP và phát hiện ra SQL Injection. Nó chặn request trước khi request đó kịp chạm tới Database phía sau. Nếu không có WAF, Database có thể đã bị đánh cắp dữ liệu. |
| IDS (Suricata)    | Suricata phát hiện server trả về quá nhiều lỗi 403 cho một IP, nhận định đây là hành vi dò quét hoặc tấn công thất bại, và thực hiện chặn IP đó để giảm tải cho WAF.                                    |

### Kết luận

Hệ thống đã phát hiện và ngăn chặn thành công một cuộc tấn công SQL Injection vào ứng dụng Web. IP tấn công 172.20.10.3 đã bị vô hiệu hóa bởi cả ModSecurity và Suricata.

Thiệt hại: Không có.

Bài học kinh nghiệm: Sự cố cho thấy vai trò không thể thay thế của Reverse Proxy tích hợp WAF. Trong mô hình này, Reverse Proxy đã chịu các cuộc tấn công, thay cho Web Server thật sự (nằm sau DMZ), đảm bảo an toàn cho hạ tầng.

## 7. Tấn công Cross-Site Scripting (XSS)

### Thông tin chung

Thời gian: 16:40:02

Đối tượng tấn công: IP 172.20.10.3

Mục tiêu: Máy chủ dmz-reverseproxy-waf

Loại hình tấn công: Reflected XSS (Cross-Site Scripting).

Kỹ thuật MITRE & ATT&CK:

- **T1059.007: Command and Scripting Interpreter: JavaScript (XSS Attempt).**
- **T1083: File and Directory**

### Diễn biến chi tiết

#### Giai đoạn 1: Gửi payload

Attacker gửi HTTP Requests chứa thẻ <script> ở URI.

Phát hiện tại Network Layer: Suricata phát hiện mẫu ký tự nguy hiểm trong gói tin TCP.

- Cảnh báo: **ET WEB\_SERVER Script tag in URI.**
- Hành động: Kích hoạt chặn IP 172.20.10.3 vào danh sách đen

| Last 250 Alert Entries. (Most recent entries are listed first) |                                                                                     |     |       |                            |                                                                                                                                                                                     |       |                                                                                                                                                                                     |       |                                                                                                                                                                                   |                                                                       |
|----------------------------------------------------------------|-------------------------------------------------------------------------------------|-----|-------|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------|
| Date                                                           | Action                                                                              | Pri | Proto | Class                      | Src                                                                                                                                                                                 | SPort | Dst                                                                                                                                                                                 | DPort | GID:SID                                                                                                                                                                           | Description                                                           |
| 12/09/2025 16:40:02                                            |  | 2   | TCP   | Attempted Information Leak | 172.20.10.2                                                                                      | 80    | 172.20.10.3   | 40814 | 1:2101201   | GPL WEB_SERVER 403 Forbidden                                          |
| 12/09/2025 16:40:02                                            |  | 1   | TCP   | Web Application Attack     | 172.20.10.3   | 40814 | 172.20.10.2                                                                                      | 80    | 1:2009714   | ET WEB_SERVER Script tag in URI Possible Cross Site Scripting Attempt |

#### Giai đoạn 2: Xử lý tại Application Layer

Gói tin đi qua lớp mạng và chạm đến Reverse Proxy. Tại đây, ModSecurity (WAF) phân tích cú pháp HTTP Request.

Phát hiện tại Application Layer :

- ModSecurity nhận diện đây là hành vi XSS thông qua luật **31105 – XSS (Cross Site Scripting) attempt.**
- Ngay lập tức, WAF từ chối phục vụ request này, kích hoạt luật **31333 – ModSecurity rejected a query.**

| Last 500 Hosts Blocked by Suricata                                                                                                                                    |                     |                                                                       |                    |              |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|-----------------------------------------------------------------------|--------------------|--------------|
| <b>Note:</b> Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab. |                     |                                                                       |                    |              |
| Blocked IP                                                                                                                                                            | Block Date/Time     | Block Alert Description                                               | Block Rule GID:SID | Remove Block |
| 172.20.10.3                                                                                                                                                           | 12/09/2025 16:14:27 | SURICATA Applayer Mismatch protocol both directions                   | 1:2260000          | ✖            |
|                                                                                                                                                                       | 12/09/2025 16:40:02 | ET WEB_SERVER Script tag in URI Possible Cross Site Scripting Attempt | 1:2009714          |              |

### Giai đoạn 3: Phản hồi & ghi nhận

Request bị chặn hoàn toàn, trả về mã lỗi 403 Forbidden cho Attacker. SIEM: Wazuh Agent 008 (Reverse Proxy) đã gửi log về Server, giúp Blue Team thấy rõ kỹ thuật tấn công **T1059.007** đang được sử dụng.

| Security Alerts              |       |                      |              |           |                                     |       |         |
|------------------------------|-------|----------------------|--------------|-----------|-------------------------------------|-------|---------|
| Time ↓                       | Agent | Agent name           | Technique(s) | Tactic(s) | Description                         | Level | Rule ID |
| > Dec 9, 2025 @ 04:40:05.294 | 008   | dmz-reverseproxy-waf | T1083        | Discovery | ModSecurity rejected a query        | 7     | 31333   |
| > Dec 9, 2025 @ 04:40:05.292 | 008   | dmz-reverseproxy-waf | T1059.007    | Execution | XSS (Cross Site Scripting) attempt. | 6     | 31105   |

### Biện pháp phòng thủ & giảm thiểu

| Lớp phòng thủ     | Vai trò                                                                                                                                                              |
|-------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| IDS (Suricata)    | Chặn dựa trên Pattern Matching, thấy chữ <script> là chặn IP ngay lập tức để giảm tải cho server.                                                                    |
| WAF (ModSecurity) | Chặn dựa trên logic ứng dụng. Nếu Attacker dùng các kỹ thuật mã hóa (encoding) để qua mặt Suricata, WAF sẽ giải mã và chặn lại. Bằng chứng là Rule 31105 trên Wazuh. |

### Kết luận

Hệ thống đã chặn đứng cuộc tấn công XSS nhờ sự phối hợp giữa IDS/IPS và WAF. Dữ liệu từ SIEM (Wazuh) cho ta cái nhìn sâu hơn về kỹ thuật tấn công (**MITRE T1059.007**), xác nhận rằng đây không phải là báo động giả mà là một nỗ lực khai thác thật sự.

## 8. Tấn công dò quét lỗ hổng tự động (NSE)

### Thông tin chung

Thời gian: 16:48:35 ngày 09/12/2025.

Đối tượng tấn công: IP 172.20.10.3.

Mục tiêu: Web Server thông qua Reverse Proxy.

Công cụ tấn công: Nmap với chế độ Scripting Engine.

Kỹ thuật MITRE ATT&CK:

- **T1595: Active Scanning.**
- **T1190: Exploit Public-Facing Application.**

## Diễn biến chi tiết

Khác với các cuộc tấn công trước chỉ quét Port hoặc OS, lần này Attacker đã sử dụng các đoạn mã tự động (scripts) để tìm kiếm lỗ hổng cụ thể trên ứng dụng Web:

### Giai đoạn 1 : Kích hoạt Scripting Engine

Attacker sử dụng công cụ Nmap nhưng bật tính năng Scripting. Tính năng này cho phép Nmap chạy các module kiểm tra lỗi bảo mật thay vì chỉ kiểm tra port đóng/mở.

Dấu hiệu nhận biết:

- Suricata phát hiện User-Agent đặc trưng của công cụ: **Mozilla/5.0 (compatible; Nmap Scripting Engine; ...)**
- Alert: **ET SCAN Nmap Scripting Engine User-Agent Detected.**

| Last 500 Hosts Blocked by Suricata                                                                                                                                    |                                            |                                                                                                                                  |                        |              |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------|------------------------|--------------|
| <b>Note:</b> Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab. |                                            |                                                                                                                                  |                        |              |
| Blocked IP                                                                                                                                                            | Block Date/Time                            | Block Alert Description                                                                                                          | Block Rule GID:SID     | Remove Block |
| 172.20.10.3                                                                                                                                                           | 12/09/2025 16:14:27<br>12/09/2025 16:48:35 | SURICATA Applayer Mismatch protocol both directions<br>ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) | 1:2260000<br>1:2009358 |              |

### Giai đoạn 2: Tấn công Web

Trong quá trình quét, Nmap đã thử truy cập vào các file nhạy cảm của hệ thống Linux (**Alert ET WEB\_SERVER /etc/passwd Detected in URI**)

Nhận định: Đây là nỗ lực khai thác lỗ hổng Directory Traversal hoặc LFI (Local File Inclusion) nhằm đọc file chứa thông tin chứa người dùng hệ thống (/etc/passwd).

Wazuh SIEM: Ghi nhận hành vi này là **Common web attack (Rule ID 31104)**, đồng thời đánh dấu các kỹ thuật **T1055, T1083, T1190**.

| Security Alerts              |       |                      |                         |                                                                  |                    |       |         |
|------------------------------|-------|----------------------|-------------------------|------------------------------------------------------------------|--------------------|-------|---------|
| Time ↓                       | Agent | Agent name           | Technique(s)            | Tactic(s)                                                        | Description        | Level | Rule ID |
| > Dec 9, 2025 @ 04:49:57.969 | 008   | dmz-reverseproxy-waf | T1055<br>T1083<br>T1190 | Defense Evasion, Privilege Escalation, Discovery, Initial Access | Common web attack. | 6     | 31104   |

### Giai đoạn 3: Ngăn chặn

Ngay khi nhận diện được chuỗi User-Agent của Nmap, Suricata đã kích hoạt lệnh chặn. Kết quả là IP 172.20.10.3 bị đưa vào Black List.

| Alert Log View Filter                                          |        |     |       |                            |                  |       |                  |       |               |                                                                           |
|----------------------------------------------------------------|--------|-----|-------|----------------------------|------------------|-------|------------------|-------|---------------|---------------------------------------------------------------------------|
| Last 250 Alert Entries. (Most recent entries are listed first) |        |     |       |                            |                  |       |                  |       |               |                                                                           |
| Date                                                           | Action | Pri | Proto | Class                      | Src              | SPort | Dst              | DPort | GID:SID       | Description                                                               |
| 12/09/2025 16:48:55                                            |        | 1   | TCP   | Web Application Attack     | 172.20.10.3<br>Q | 47470 | 172.20.10.2<br>Q | 80    | 1:2009358<br> | ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) |
| 12/09/2025 16:48:35                                            |        | 1   | TCP   | Web Application Attack     | 172.20.10.3<br>Q | 47482 | 172.20.10.2<br>Q | 80    | 1:2009358<br> | ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) |
| 12/09/2025 16:47:25                                            |        | 2   | TCP   | Attempted Information Leak | 172.20.10.3<br>Q | 44174 | 172.20.10.2<br>Q | 80    | 1:2049400<br> | ET WEB_SERVER /etc/passwd Detected in URI                                 |

## Biện pháp phòng thủ & giảm thiểu

| Lớp phòng thủ | Vai trò                                                                                                                                                                              |
|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Suricata      | User-Agent Filtering: Phát hiện công cụ tấn công dựa trên User-Agent mà công cụ đó gửi đi. Nmap mặc định sẽ khai báo danh tính của nó, giúp Suricata dễ dàng nhận diện và chặn đứng. |
| SIEM (Wazuh)  | Threat Intelligence: Tương quan hành vi quét mạng với các hành vi tấn công Web phổ biến (Common web attack), giúp xác định rõ mục đích của Attacker là tìm lỗ hổng Web.              |

## Kết luận

Hệ thống đã đối mặt với một đợt rà quét lỗ hổng tự động mức độ cao. Attacker 172.10.20.3 đã sử dụng Nmap Scripting Engine để cố gắng tìm kiếm các file cấu hình nhạy cảm (/etc/passwd). Tuy nhiên, cuộc tấn công đã bị vô hiệu hóa bởi IPS nhờ vào chữ ký của công cụ Nmap.

Bài học kinh nghiệm:

- Hardening: Attacker chuyên nghiệp sẽ thường thay đổi (spoof) User-Agent để giả dạng trình duyệt Chrome/Firefox nhằm qua mặt IPS. Do đó, cần kết hợp thêm WAF để phân tích hành vi (behavior) thay vì chỉ dựa vào chuỗi định danh (signature).
- Lỗ hổng web: Cảnh báo /etc/passwd là lời nhắc nhở quan trọng về việc kiểm tra các lỗ hổng LFI trên Web Server.

## 9. Tấn công thực thi mã từ xa (RCE – SHELLSHOCK)

### Thông tin chung

Thời gian: 16:54:12 ngày 09/12/2025.

Đối tượng tấn công: IP 172.20.10.3

Mục tiêu:

- IP đích: 172.20.10.2
- Lỗ hổng mục tiêu: **CVE-2014-6271 (Shellshock / Bashdoor)**.

Loại hình tấn công: Remote Code Execution (RCE) / Privilege Escalation.

## Diễn biến chi tiết

Attacker đã cố gắng khai thác lỗ hổng trong trình thông dịch lệnh Bash để giành quyền kiểm soát máy chủ.

## Giai đoạn 1: Gửi payload khai thác

| Last 250 Alert Entries. (Most recent entries are listed first) |        |     |       |                                        |             |       |             |       |           |                                              |
|----------------------------------------------------------------|--------|-----|-------|----------------------------------------|-------------|-------|-------------|-------|-----------|----------------------------------------------|
| Date                                                           | Action | Pri | Proto | Class                                  | Src         | SPort | Dst         | DPort | GID:SID   | Description                                  |
| 12/09/2025 16:54:12                                            |        | 2   | TCP   | Attempted Information Leak             | 172.20.10.2 | 80    | 172.20.10.3 | 35324 | 1:2101201 | GPL WEB_SERVER 403 Forbidden                 |
| 12/09/2025 16:54:12                                            |        | 1   | TCP   | Attempted Administrator Privilege Gain | 172.20.10.3 | 35324 | 172.20.10.2 | 80    | 1:2022028 | ET WEB_SERVER Possible CVE-2014-6271 Attempt |

Attacker gửi một HTTP Request có chứa các biến môi trường độc hại. Đặc điểm của Shellshock là chèn các lệnh thực thi sau định nghĩa hàm (function definition)

Phát hiện tại Network Layer (Suricata):

- Hệ thống phát hiện chữ ký tấn công khớp với **CVE-2014-6271**.
- Cảnh báo: **ET WEB\_SERVER Possible CVE-2014-6271 Attempt (GID:SID 1:2022028)**
- Suricata đánh dấu hành vi này là Attempted Administrator Privilege Gain (Cố gắng chiếm quyền quản trị) - mức độ cảnh báo cao nhất.

## Giai đoạn 2: Xử lý và ngăn chặn tại WAF

Payload đi qua Network Layer và bị ModSecurity (WAF) chặn lại.

Ghi nhận từ SIEM (Wazuh):

- Wazuh định danh chính xác tên cuộc tấn công là **Shellshock attack attempt (Rule ID 31166)**.
- **T1068: Exploitation for Privilege Escalation (Khai thác để leo thang đặc quyền)**.
- **T1190: Exploit Public-Facing Application (Khai thác ứng dụng công khai)**.

Kết quả: ModSecurity rejected a query.

|   |                            |     |                      |                |                                      |                              |   |       |
|---|----------------------------|-----|----------------------|----------------|--------------------------------------|------------------------------|---|-------|
| > | Dec 9, 2025 @ 04:54:16.335 | 008 | dmz-reverseproxy-waf | T1083          | Discovery                            | ModSecurity rejected a query | 7 | 31333 |
| > | Dec 9, 2025 @ 04:54:16.292 | 008 | dmz-reverseproxy-waf | T1068<br>T1190 | Privilege Escalation, Initial Access | Shellshock attack attempt    | 6 | 31166 |

## Giai đoạn 3: Phản hồi

Web Server trả về mã lỗi 403 Forbidden, xác nhận rằng yêu cầu độc hại đã bị từ chối phục vụ.

### **Biện pháp phòng thủ & giảm thiểu**

| Lớp phòng thủ     | Vai trò                                                                                                                                                                      |
|-------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| IPS (Suricata)    | Signature Matching: Sử dụng bộ luật Emerging Threats (ET) để phát hiện chuỗi ký tự đặc trưng của Shellshock (() { ::};) ngay trong gói tin.                                  |
| WAF (ModSecurity) | Virtual Patching: Ngay cả khi Web Server phía sau chưa được vá lỗi Bash, WAF đứng trước (Reverse Proxy) đã chặn request này, đóng vai trò như một bản vá ảo bảo vệ hệ thống. |

### **Kết luận**

Cuộc tấn công RCE sử dụng lỗ hổng Shellshock (CVE-2014-6271) từ IP 172.20.10.3 đã thất bại hoàn toàn. Hệ thống phòng thủ đa lớp đã nhận diện và vô hiệu hóa payload trước khi nó kịp thực thi lệnh trên server. Đây là cuộc tấn công nguy hiểm nhất trong chuỗi sự kiện, vì nếu thành công, Attacker sẽ có quyền thực thi lệnh trực tiếp (Remote Shell) trên máy chủ với quyền của user chạy Web Service.